Title: Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization

Team ID : SWTID-2026-6097

Group Details:

S.no	Name	College Name	Contact
1	APARNA SURESH	Sree Narayana Guru College	aparnasureshaparnasuresh644@gmail.com
2	ABHINAV K	Sree Narayana Guru College	abhinavkannan205@gmail.com
3	ADHVAITH S NAIR	Sree Narayana Guru College	adhvaithsnair042@gmail.com
4	ADITHYAN C	Sree Narayana Guru College	adithyanmkpmsd@gmail.com
5	MOHAMMED HARSHAD M H	Sree Narayana Guru College	achuachuzz479@gmail.com

Project Details:

Title: Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization

Introduction:

Traditional security models that depend on network perimeters are no longer sufficient to protect sensitive data and applications. As a result, many organizations are adopting the **Zero Trust security model**, regardless of whether they are inside or outside the network.**Zscaler** is a cloud-based security platform that enables organizations to implement **Zero Trust Network Access (ZTNA)** by providing secure connectivity between users and applications without exposing internal networks. Instead of granting broad network access like traditional VPN solutions, Zscaler connects users directly to specific applications based on identity, security policies, and authentication verification.To strengthen authentication and access control, Zscaler can be integrated with Identity Providers (IdPs) such as **Microsoft Azure Active Directory**, **Okta**, and **Active Directory**. Identity Providers manage user identities and authentication processes, enabling secure login mechanisms such as **Single Sign-On (SSO)** and **Multi-Factor Authentication (MFA)**. When integrated with Zscaler, these identity platforms ensure that only authenticated and authorized users can access enterprise applications.Through this integration, authentication requests are redirected to the Identity Provider, where user credentials are verified.. This approach enhances security, improves user experience, and reduces the risk of unauthorized access.By combining Zscaler's cloud security platform with trusted identity management systems like Azure AD, Okta, and Active Directory, organizations can establish a secure, scalable, and identity-driven access framework that protects corporate resources while enabling seamless user authentication and authorization.

Abstract:

This project focuses on integrating the **Zscaler** cloud security platform with enterprise Identity Providers such as **Microsoft Azure Active Directory**, **Okta**, and **Active Directory** to enable secure authentication and authorization for organizational users. The primary objective of this integration is to create a unified identity framework that provides seamless **Single Sign-On (SSO)** and centralized access control across all Zscaler services. By using trusted corporate directories as the main authentication source, organizations can eliminate the need for multiple credentials and establish a strong foundation for a modern **Zero Trust security architecture**. The integration leverages industry-standard authentication protocols such as **SAML (Security Assertion Markup Language)**, **OIDC (OpenID Connect)**, and **SCIM (System for Cross-domain Identity Management)** to securely delegate authentication requests to identity providers. This approach ensures that every user attempting to access enterprise applications is verified through trusted identity platforms while enforcing consistent security policies such as **Multi-Factor Authentication (MFA)**. As a result, it improves both security and user experience by reducing password fatigue and ensuring that only authenticated and authorized users gain access to resources.

Use Case Scenarios:

1. Secure Remote Workforce Access

Many organizations support remote or hybrid work environments where employees access corporate resources from outside the office network. By integrating Zscaler with identity providers, remote users authenticate through trusted identity platforms before accessing applications. Once authenticated, Zscaler securely connects the user directly to the required application without exposing the internal network. This ensures secure access while maintaining productivity for remote employees.

2. Single Sign-On (SSO) for Enterprise Applications

Organizations often use multiple cloud and internal applications, which can create challenges for users managing different login credentials. With Identity Provider integration, users can log in once through Azure AD, Okta, or Active Directory and gain seamless access to authorized applications via Zscaler. This Single Sign-On (SSO) capability improves user experience while maintaining strong authentication controls.

3. Multi-Factor Authentication for Enhanced Security

Cyber threats such as credential theft and phishing attacks make strong authentication mechanisms essential. Identity providers can enforce Multi-Factor Authentication (MFA), requiring users to verify their identity using additional factors such as mobile authentication apps or biometric verification. When integrated with Zscaler, MFA ensures that only legitimate users are granted access to enterprise resources.

4. Secure Access to Internal Applications

Traditional VPN solutions expose internal networks to users once they are connected. Zscaler, combined with identity provider authentication, allows users to access only specific applications rather than the entire network. Access is granted based on identity, security policies, and device posture, significantly reducing the attack surface.

5. Automated User Provisioning and De-Provisioning

Identity providers manage the lifecycle of user accounts within an organization. Through automated provisioning protocols, user accounts can be automatically created, updated, or removed when employees join, change roles, or leave the organization. This ensures that only active and authorized users maintain access to applications secured by Zscaler.

6. Centralized Identity and Access Management

By integrating Zscaler with enterprise identity platforms, organizations can manage user identities and access policies from a single centralized system. Administrators can define role-based access controls, monitor authentication events, and quickly respond to suspicious login attempts, improving overall security governance.

7. Secure Access for Third-Party Partners

Organizations often collaborate with vendors, contractors, and external partners who require access to certain applications. Using identity-based authentication through integrated identity providers, organizations can grant limited and controlled access to specific resources without exposing the broader network infrastructure.

STAGE 1

Title of the project: -

Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization

Overview:

The integration of Zscaler with Identity Providers (IdPs) such as Microsoft Azure Active Directory, Okta, and Active Directory plays a crucial role in modern cybersecurity frameworks that focus on identity-based access control. As organizations increasingly adopt cloud services and remote work environments, traditional perimeter-based security models are no longer sufficient to protect enterprise resources. This has led to the adoption of Zero Trust security architecture, where access decisions are based on verified identity rather than network location.

Zscaler is a cloud-native security platform that provides secure access to internet and private applications without exposing internal networks. By integrating Zscaler with enterprise identity providers, organizations can centralize authentication and authorization processes. Identity providers manage user identities, authentication credentials, and access policies, ensuring that only authorized users are granted access to organizational resources.

Through this integration, when a user attempts to access an application secured by Zscaler, the authentication request is redirected to the configured identity provider. The identity provider verifies the user's credentials using authentication mechanisms such as Single Sign-On (SSO) and Multi-Factor Authentication (MFA). Once the identity is successfully verified, Zscaler enforces security policies and allows controlled access to the requested application.This integration not only strengthens security but also simplifies identity management by enabling centralized user provisioning, role-based access control, and automated lifecycle management. It also improves the user experience by reducing the need for multiple login credentials across different systems.

Overall, integrating Zscaler with identity providers creates a secure, scalable, and efficient authentication framework that supports modern enterprise security requirements while enabling seamless and secure access to applications and services

List of Vulnerability Table:

S.no	Vulnerability Name	CWE/CVE - No
1	Improper Sanitization of File Paths	CWE- 284
2	Invalid Certificate	CWE-395
3	Missing X-Frame-Options Header	CWE-1021
4	X-Content-Type Options Header Missing	CWE-918
5	Drupal Ajax API shows JSONP not disabled by default	CWE-937,1035
6	Drupal Api Vulnerability	CWE-20
7	Improper API Filtration	CWE-79
8	Denial of Service	CWE-400
9	TLS Version 1.0 Protocol Detection	CWE-327
10	web.config File Information Disclosure	CWE-497

REPORT:-

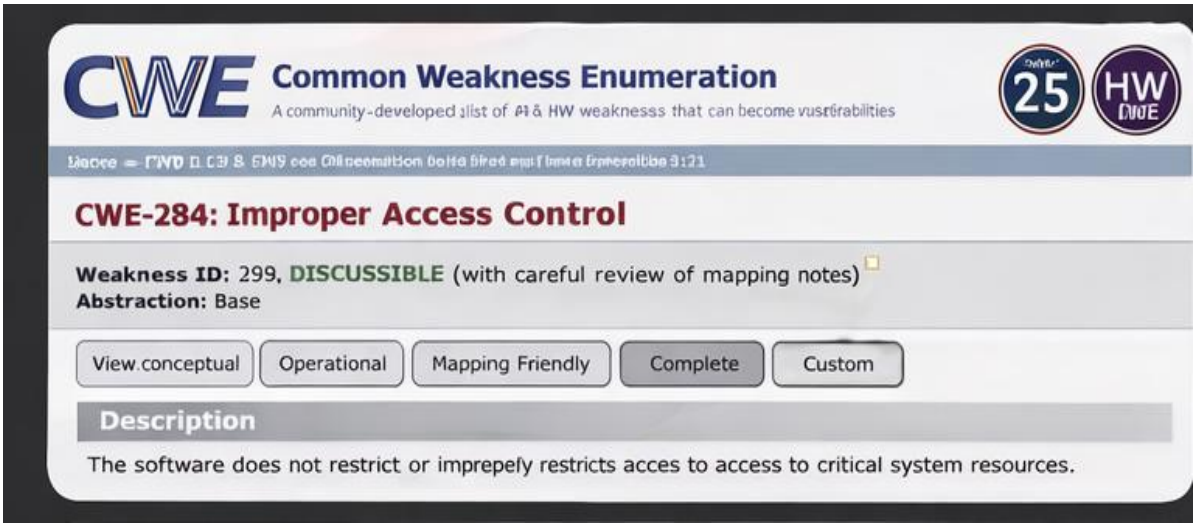
1) Vulnerability Name:- Improper Sanitization of File

Paths CWE/CVE : - CWE-284

OWASP/SANS Category:- A01:2021-Broken Access Control

Description:- The product does not restrict or incorrectly restricts access to a resource from an unauthorized actor.

Business Impact:- This vulnerability is significant, as it can lead to unauthorized access to sensitive data or files, potentially causing data breaches, privacy violations, and loss of user trust. Affected sites may also require configuration changes after applying a security release.



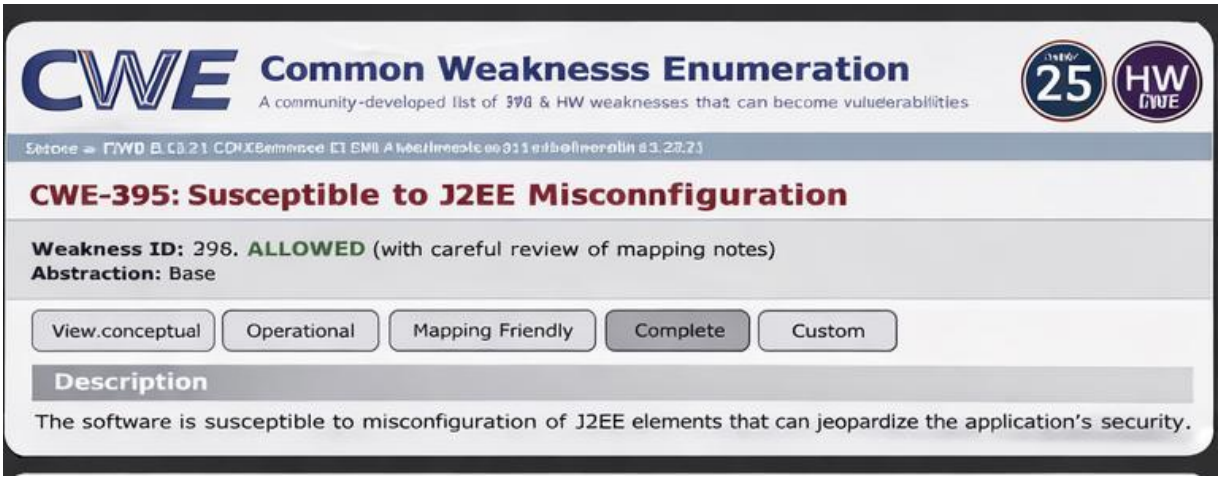
2) Vulnerability Name :- **Invalid Certificate**

CWE/CVE:- CWE395

OWASP/SANS Category: Identification and Authentication Failures

Description:- When a certificate is invalid or malicious, it might allow an attacker to spoof a trusted entity by interfering in the communication path between the host and client. The product might connect to a malicious host while believing it is a trusted host, or the product might be deceived into accepting spoofed data that appears to originate from a trusted host.

Business Impact- Improper certificate validation can lead to a range of security threats which includes Man-in-the-middle attacks(Attackers can intercept communication between two parties and read or modify the data exchanged between them),Data breaches:(Attackers can gain unauthorized access to sensitive information or sensitive systems, leading to data breaches),Malware distribution(Attackers can use fake digital certificates to distribute malicious software or infect systems with malware).



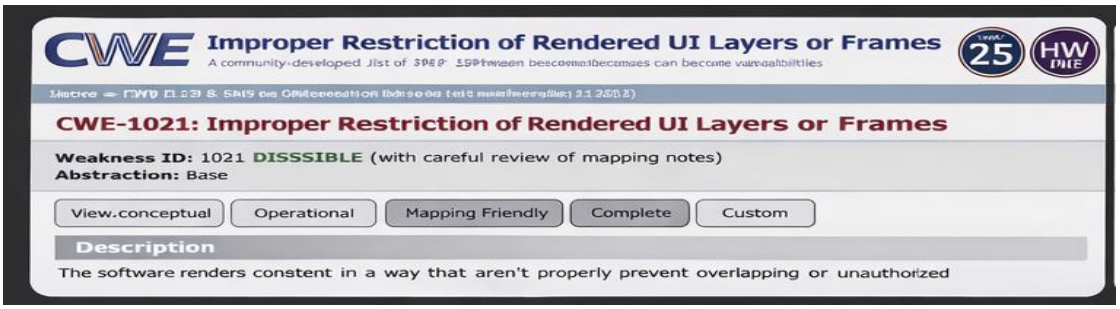
3) Vulnerability Name : **Missing X-Frame-Options Header** **CWE/CVE**:-

CWE-1021

OWASP/SANS Category:- A04:2021-Insecure Design

Description:- A web application is expected to place restrictions on whether it is allowed to be rendered within frames, iframes, objects, embed or applet elements. Without the restrictions, users can be tricked into interacting with the application when they were not intending to.

Business Impact:- This enables path to the attackers to manipulate or gain unauthorized access to user interface elements, potentially leading to deceptive or malicious user interactions. This can result in data leakage, fraud, user distrust, and reputational damage, undermining the integrity and trustworthiness of the application and causing financial losses..



4) Vulnerability Name :- **X-Content-Type Options Header Missing**

CWE/CVE:- CWE-918

OWASP/SANS Category:- A10:2021 – Server-Side Request Forgery (SSRF)

Description:- The web server receives a URL or similar request from an upstream component and retrieves the contents of this URL, but it does not sufficiently ensure that the request is being sent to the expected destination.

Business Impact:- The header missing impact Data Exposure(Attackers might force the server to render sensitive data as HTML, leading to data exposure),Security Risks(Content type manipulation can increase security risks, potentially leading to breaches, data leaks, and unauthorized access), Brand and Reputation Damage(Successful attacks that exploit SSRF vulnerabilities can harm the organization's reputation and trustworthiness)

5) Vulnerability Name :- **Drupal Ajax API shows JSONP not disabled by default**

CWE/CVE:- CWE-937,1035

OWASP/SANS Category:- A06:2021-Vulnerable and Outdated Components

Description:- Vulnerable and outdated components refer to using software libraries, modules, or dependencies within a web application that have known security issues or are not updated to the latest secure versions. This can include plugins, frameworks, or APIs that are no longer maintained or have publicly documented vulnerabilities

Business Impact:- The presence of vulnerable and outdated components in a web application poses significant security risks. Attackers can ex.ploit these weaknesses to gain unauthorized access, inject malicious code, steal sensitive data, or disrupt the system's operation. The potential business impacts include compromised user data, damaged reputation, legal consequences, and financial losses due to breach recovery and remediation efforts.

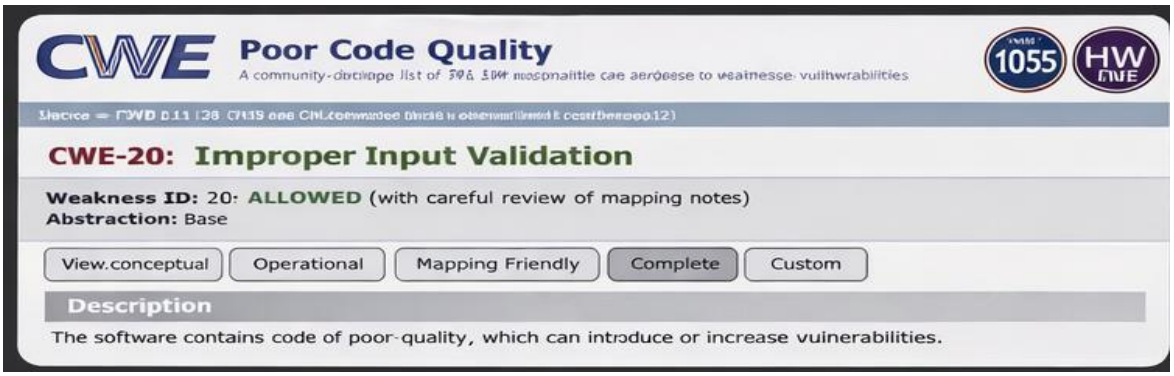
6) Vulnerability Name :- **Drupal Api Vulnerability**

Name or Path CWE/CVE:- CWE-**20**

OWASP/SANS Category:- A03:2021 – Injection

Description:- The product receives input or data, but it does not validate or incorrectly validates that the input has the properties that are required to process the data safely and correctly.

Business Impact:- The impact of a successful SQL injection attack can be devastating for businesses. It can result in unauthorized access to sensitive information, data theft, financial losses, damage to reputation, and legal consequences. Depending on the nature of the application and data involved, SQL injection can lead to compliance violations, customer trust erosion, and operational disruption. .



7)Vulnerability Name :- **Improper API Filtration**
CWE/CVE:- CWE-79

OWASP/SANS Category:- A07-2017: Cross-site Scripting (XSS)

Description:- The product does not neutralize or incorrectly neutralizes user-controllable input before it is placed in output that is used as a web page that is served to other users..

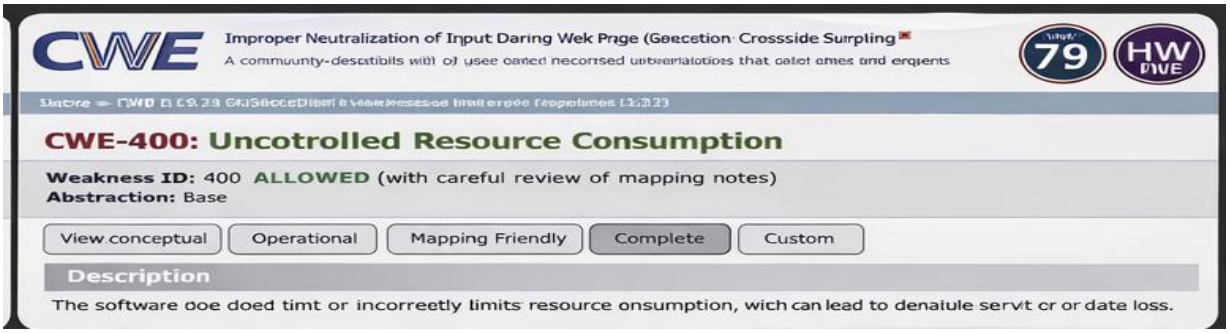
Business Impact: If exploited, this vulnerability allows attackers to inject malicious scripts into web pages, which can be viewed by other users. The potential business impacts include data theft, unauthorized access, compromised user accounts, damaged reputation, and financial losses. Attackers can use XSS to steal sensitive information, such as user credentials, personal data, or financial details, leading to regulatory compliance violations and legal liabilities. Additionally, defacement or manipulation of website content can erode customer trust and result in lost revenue

8)Vulnerability Name:- **Denial of Service**

CWE/CVE:- CWE-400

OWASP/SANS Category:
Description:- : The Denial of Service (DoS) attack is focused on making a resource (site, application, server) unavailable for the purpose it was designed. There are many ways to make a service unavailable for legitimate users by manipulating network packets, programming, logical, or resources handling vulnerabilities, among others. If a service receives a very large number of requests, it may cease to be available to legitimate users. In the same way, a service may stop if a programming vulnerability is exploited, or the way the service handles resources it uses.

BUSINESS IMPACT:successfully exploited, it involves overwhelming a system or application with excessive demands on its resources. This can lead to a range of disruptive consequences. The targeted system may experience significant slowdowns, or even complete unresponsiveness, making it difficult or impossible for legitimate users to access.



9)Vulnerability Name:- **TLS Version 1.0 Protocol Detection**

CWE/CVE:- CWE-327

OWASP/SANS Category: A02:2021-Cryptographic Failures

Description:- The product uses a broken or risky cryptographic algorithm or protocol.

Business Impact:- TLS 1.0 is an outdated and vulnerable encryption protocol, and its use can expose sensitive data to potential security threats. This not only jeopardizes the integrity of customer information and payment details but also tarnishes the company's reputation. The business may face legal consequences, loss of customer trust, and decreased revenue as security- conscious users avoid the site due to its security vulnerabilities. Immediate action is necessary to upgrade to a more secure TLS version to safeguard data, ensure compliance, and maintain customer confidence

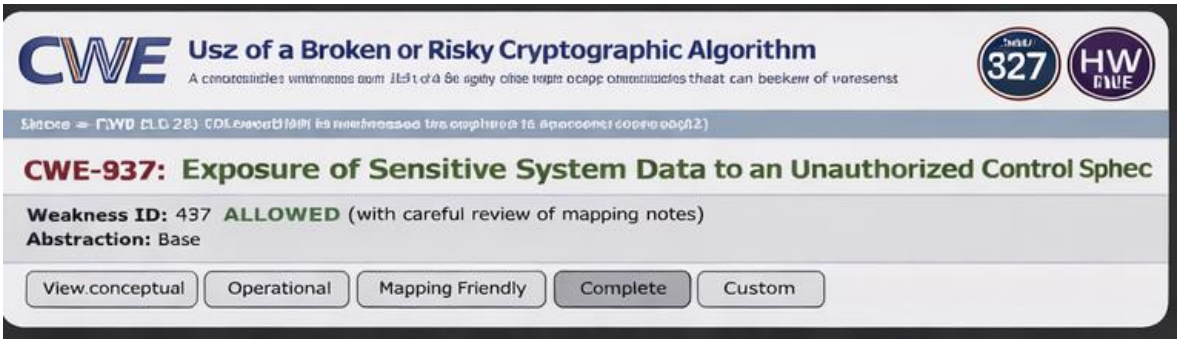
10)Vulnerability Name: **web.config File Information Disclosure**

CWE-497:

Description: An information disclosure vulnerability exists in the remote web server due to the disclosure of the web.config file. An unauthenticated, remote attacker can exploit this, via a simple GET request, to disclose potentially sensitive configuration information.

Business Impact: It exposes sensitive configuration details, including database connection strings and encryption keys, to potential attackers. This could lead to

unauthorized access, data breaches, and system compromise. The impact includes financial losses, damage to reputation, and legal liabilities as the organization's security and customer trust are compromised



STAGE 2

Overview:

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

1) **Vulnerability Scanning Tool**

Tenable Nessus is a security tool used to scan computers, servers, and networks to identify security vulnerabilities and weaknesses.

2) **Detects Security Risks**

It helps detect issues such as outdated software, missing security patches, weak configurations, and known vulnerabilities in systems.

3) **Uses CVE Database**

Nessus compares scanned systems with vulnerability databases like **Common Vulnerabilities and Exposures (CVE)** to identify known security threats.

4) **Provides Detailed Reports**

After scanning, it generates detailed reports showing vulnerability descriptions, severity levels, and recommended solutions.

5) **Improves System Security**

By identifying and fixing vulnerabilities found by Nessus, organizations can improve their network security and reduce the risk of cyberattacks.

Target website :- http://testfire.net/

Target ip address: - 65.61.137.117

List of vulnerability: -

s.no	Vulnerability name	Severity	plugins
1	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
3	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875
4	ICMP Timestamp Request Remote Date Disclosure	INFO	10114
5	Additional DNS Hostnames	INFO	46180
6	Apache Tomcat Detection	INFO	39446
7	Common Platform Enumeration (CPE)	INFO	45590
8	Device Type	INFO	54615
9	HSTS Missing From HTTPS Server	INFO	84502
10	HTTP Server Type and Version	INFO	10107

REPORT: -

1) Vulnerability Name

TLS Version 1.0 Protocol Detection

Plugin ID: 104743

Description:

The remote service supports TLS version 1.0, which is an outdated cryptographic protocol used to secure communications over the network. TLS 1.0 has known security weaknesses and is deprecated by modern security standards such as PCI DSS and NIST. Attackers may exploit protocol weaknesses to perform downgrade attacks or intercept encrypted communication.

BusinessImpact:

Using deprecated TLS versions may expose sensitive data to interception or cryptographic attacks. It can also lead to non-compliance with security standards, potentially affecting regulatory requirements and the organization's security posture.

2) Vulnerability Name

TLS Version 1.1 Protocol Deprecated

Plugin ID: 157288

Description:

The server supports TLS version 1.1, which has been deprecated by major browsers and security standards. While more secure than TLS 1.0, it still lacks modern cryptographic protections provided by TLS 1.2 and TLS 1.3.

BusinessImpact:

Continued support of TLS 1.1 increases the risk of cryptographic weaknesses and may allow attackers to exploit outdated encryption mechanisms. This may also cause compliance issues and compatibility problems with modern clients.

3) Vulnerability Name

SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam)

Plugin ID: 83875

Description:

The server supports weak Diffie-Hellman key exchange parameters (≤1024 bits). This vulnerability, known as Logjam, allows attackers with sufficient computational resources to downgrade encrypted sessions and potentially decrypt communications.

BusinessImpact:

Attackers may intercept and decrypt encrypted traffic, compromising sensitive information such as credentials, financial data, or confidential communications.

4) Vulnerability Name

ICMP Timestamp Request Remote Date Disclosure

Plugin ID: 10114

Description:

The host responds to ICMP timestamp requests, which allow remote systems to determine the current system time of the server. This information is typically used for network diagnostics but can reveal system timing details.

BusinessImpact:

Attackers can use timestamp information for reconnaissance activities, including identifying system uptime and assisting in time-based attacks or network mapping.

5) Vulnerability Name

Additional DNS Hostnames Detected

Plugin ID: 46180

Description:

The scanner detected additional DNS hostnames associated with the target system. These hostnames may reveal alternative domains, subdomains, or services running on the same infrastructure.

BusinessImpact:
Exposed DNS information can provide attackers with additional attack surfaces, enabling them to target other services or applications within the same infrastructure.

6) Vulnerability Name

Apache Tomcat Detection

Plugin ID: 39446

Description:
The scan detected that the target server is running Apache Tomcat, a widely used web application server for Java-based applications.

BusinessImpact:
Knowing the server software allows attackers to identify specific vulnerabilities related to that software version, potentially enabling targeted attacks if the server is not properly patched.

7) Vulnerability Name

Common Platform Enumeration (CPE)

Plugin ID: 45590

Description:
The scanner identified the Common Platform Enumeration (CPE) details of the target system. CPE is a standardized method used to identify software, hardware, and operating systems.

BusinessImpact:
Exposure of platform details can help attackers identify known vulnerabilities associated with the detected software or hardware versions.

8) Vulnerability Name

Device Type Detection

Plugin ID: 54615

Description:

The scanner detected the type of device running the service, such as a web server, network device, or application server.

BusinessImpact:

Information about device types can assist attackers in planning targeted attacks, focusing on vulnerabilities specific to that device category.

9) Vulnerability Name

HSTS Missing From HTTPS Server

Plugin ID: 84502

Description:

The HTTPS server does not implement HTTP Strict Transport Security (HSTS). HSTS instructs browsers to only communicate with the server over secure HTTPS connections.

BusinessImpact:

Without HSTS, users may be vulnerable to SSL stripping attacks, where attackers downgrade secure HTTPS connections to insecure HTTP and intercept sensitive information.

10) Vulnerability Name

HTTP Server Type and Version Disclosure

Plugin ID: 10107

Description:

The web server reveals its type and version information in HTTP response headers. This information may include details such as the web server software and version number.

BusinessImpact:

Attackers can use this information to identify known vulnerabilities in specific server versions, increasing the likelihood of successful targeted attacks.

STAGE 3:

Report:

Title: - Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

Zscaler Identity Provider (IdP) integration replaces traditional VPN-based authentication with a modern Zero Trust security model where access decisions are based on user identity rather than network location. Legacy VPN systems often create security risks such as broad network access, exposure to internet-based attacks, high latency due to traffic routing through data centers, and complex infrastructure management. By integrating Zscaler with identity providers such as Microsoft Entra ID (Azure AD), Okta, and on-premises Active Directory, organizations can implement secure authentication using protocols like SAML, OpenID Connect (OIDC), LDAP, and SCIM for automated user provisioning and lifecycle management. The Zero Trust approach ensures continuous verification, least-privilege access, and micro-segmentation, allowing users to connect only to specific applications instead of the entire network. Successful implementation requires careful planning, including application discovery, user group definition, identity source architecture, infrastructure readiness, and proper configuration of authentication and directory connectors such as the Zscaler Authentication Bridge (ZAB). Overall, this integration improves security, simplifies identity management, enhances user experience, and provides scalable cloud-based access control for modern enterprise environments.

CONCLUSION:

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

In Stage 1, understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages.

Stage 2 delved into the intricacies of Nessus reports, emphasising the significance of detailed vulnerability assessments. Analysing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures.

Stage 3 The replacement of the legacy VPN architecture with a cloud-native Zscaler Zero Trust solution marks a pivotal transformation in the organization's security posture. By shifting from a network-centric to an application-centric model, this project successfully eliminates the expanded attack surface inherent in publicly exposed VPN concentrators and completely eradicates the risk of lateral movement. The implementation of Zscaler Private Access (ZPA) ensures that users are connected only to specific applications after rigorous identity and device verification, rendering the internal network invisible. This modernization not only fortifies defenses against sophisticated cyber threats but also delivers a superior, low-latency experience for the hybrid workforce, establishing a future-ready security foundation..

Considering the future scope, Stage 1 illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

Stage 2 highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures.

Stage 3 The integration of Zscaler with enterprise Identity Providers successfully establishes a unified identity framework that replaces legacy VPN architectures with a modern Zero Trust security model. This project delivers seamless Single Sign-On capabilities across all Zscaler services while enforcing consistent security policies including Multi-Factor Authentication and conditional access based on user identity and context. Automated user provisioning via SCIM significantly reduces administrative overhead by eliminating manual account management and ensuring immediate deprovisioning when users leave the organization. The implementation of identity-based micro-segmentation effectively prevents lateral movement by connecting users to specific applications rather than the entire network. By

leveraging industry-standard protocols including SAML, OIDC, and LDAP, the integration preserves existing investments in identity infrastructure while enabling cloud-delivered security. User experience is transformed through frictionless authentication and reduced latency from Zscaler's global cloud footprint. Security posture is enhanced through real-time policy enforcement and comprehensive audit logging of all access attempts. This integration lays a robust foundation for future identity-centric security initiatives aligned with Zero Trust principles

Topics Explored

- Legacy authentication challenges with traditional VPN architectures
- Limitations of network-based security models and need for modernization
- Fundamentals of **Zero Trust Architecture (ZTA)**
- Principles of **least privilege access, continuous verification, and micro-segmentation**
- Identity-based access control using modern **Identity Providers (IdPs)**
- Integration of **Zscaler with Microsoft Entra ID (Azure AD), Okta, and Active Directory**
- Use of authentication protocols such as **SAML 2.0, OpenID Connect (OIDC), LDAP, and SCIM**
- Automated **user provisioning and lifecycle management** through SCIM
- Deployment of **Zscaler Authentication Bridge (ZAB)** for on-premises Active Directory integration
- **Application discovery and categorization** for secure access control
- **User group definition and attribute mapping** for policy-based access management

- **Infrastructure readiness assessment** including network, DNS, and endpoint compatibility
- Implementation of **Azure AD SAML configuration and Okta OIDC integration**
- Design of a **secure, scalable Zero Trust access model replacing legacy VPN solutions**

Tools Explored

- **Zscaler Internet Access (ZIA)** – Provides secure internet access and cloud-based security enforcement for users.
- **Zscaler Private Access (ZPA)** – Enables secure application access using Zero Trust architecture without exposing internal networks.
- **Zscaler Admin Portal** – Used to configure authentication settings, policies, and identity provider integrations.
- **Microsoft Entra ID (Azure AD)** – Cloud-based identity provider used for authentication, SAML configuration, and user management.
- **Okta Identity Platform** – Identity and access management platform used for OIDC authentication and user provisioning.
- **Active Directory (AD)** – On-premises directory service used for managing users, groups, and authentication.
- **Zscaler Authentication Bridge (ZAB)** – Connector used to integrate on-premises Active Directory with Zscaler securely.
- **SCIM (System for Cross-domain Identity Management)** – Protocol used for automated user provisioning and synchronization.
- **SAML 2.0 (Security Assertion Markup Language)** – Authentication protocol used for Single Sign-On (SSO).
- **OpenID Connect (OIDC)** – Modern authentication protocol used for secure API-based authentication.
- **Zscaler Client Connector** – Endpoint agent that routes user traffic securely through the Zscaler cloud.

- **Network Discovery and Monitoring Tools** – Used to identify applications, services, and network access requirements.

•